

SASD

Architekturprüfung  
und Architekturdokument

SASD Desktop Secret Manager

# Architekturprüfung und überarbeitetes Architekturdokument

*SASD Desktop Secret Manager - Abgleich mit überarbeitetem Pflichtenheft einschließlich HTTPS/TLS-Zertifikatsverwaltung*

|                                                                                                                                                                                                                                                                                                   |                                                                                                                       |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Dokumenttyp                                                                                                                                                                                                                                                                                       | Architekturprüfung und überarbeitetes Architekturdokument                                                             |
| Projekt                                                                                                                                                                                                                                                                                           | SASD Desktop Secret Manager                                                                                           |
| Dokumentziel                                                                                                                                                                                                                                                                                      | Abgleich des bestehenden Architekturdokuments mit dem überarbeiteten Pflichtenheft und Aktualisierung der Architektur |
| Schwerpunkte                                                                                                                                                                                                                                                                                      | HTTPS/TLS-Zertifikatsverwaltung, Schichtenmodell, Datenmodell, Security, UI, Tests, Roadmap, ADRs                     |
| Status                                                                                                                                                                                                                                                                                            | Arbeits- und Entscheidungsgrundlage für Dokumentations- und Implementierungsabgleich                                  |
| Stand                                                                                                                                                                                                                                                                                             | 18.05.2026                                                                                                            |
| Leserhinweis: Das Dokument trennt bewusst Prüfungsergebnis und Zielarchitektur. Zuerst wird begründet, welche Änderungen notwendig sind; danach folgt die aktualisierte Architektur in einer Form, die als Ersatz oder Fortschreibung des bestehenden Architekturdokuments verwendet werden kann. |                                                                                                                       |

# Inhaltsübersicht

Management Summary und Prüfungsergebnis

1. 1. Prüfgrundlage und Abgleichsmethode
2. 2. Ergebnis der Architekturprüfung: Was muss geändert werden?
3. 3. Dinge, die ausdrücklich nicht geändert werden sollten
4. 4. Überarbeitetes Zielbild der Architektur
5. 5. Aktualisiertes Schichtenmodell
6. 6. Aktualisiertes Domain-Modell
7. 7. Aktualisierte Application-Schicht
8. 8. Aktualisierte Security-Architektur
9. 9. Storage, Dateiformat und Migration
10. 10. UI- und UX-Architektur
11. 11. Password-Safe-Interop und Zertifikatsdaten
12. 12. Laufzeitsichten und Kernabläufe
13. 13. Test- und Verifikationssicht
14. 14. ADRs und Dokumentationsfolgen
15. 15. Aktualisierte Roadmap und Umsetzungspakete
16. 16. Risiken und bewusste Grenzen
17. 17. Konkrete Änderungsliste für das bestehende Architekturdokument
18. Anhang A - Empfohlene neue oder geänderte Klassen
19. Anhang B - Abnahme- und Review-Checkliste

## Management Summary und Prüfungsergebnis

Das überarbeitete Pflichtenheft macht Änderungen am Architekturdokument erforderlich. Die Grundarchitektur muss nicht neu erfunden werden: Domain, Application, Security, Storage, Interop.PasswordSafe, WinForms und Tests bleiben tragfähig. Aber das Architekturdokument muss inhaltlich aktualisiert werden, damit es die neue fachliche Breite, die aktualisierte V1/V1.x/V2-Zuordnung und insbesondere die HTTPS/TLS-Zertifikatsverwaltung korrekt abbildet.

Die wichtigste Änderung ist nicht eine neue technische Plattform, sondern eine präzisere Architekturgrenze: Zertifikate werden als fachlicher Secret-Typ in das bestehende interne Modell aufgenommen. V1 verwaltet Zertifikatsmetadaten und sensible Key-/PFX-Informationen lokal und strukturiert. V1 ist aber keine PKI-Suite, kein ACME-Client und kein automatisches Deployment-Werkzeug.

**Prüfergebnis.** Ja, das Architekturdokument sollte aktualisiert werden. Die Änderung ist architektonisch moderat, aber dokumentarisch wichtig: neue EntryTypes, Zertifikatsfeldgruppen, Such-/Filterlogik, Security-Redaction, UI-Verhalten, Tests, Roadmap und ADR-Liste müssen ergänzt werden.

### 0.1 Kurzbewertung des Änderungsbedarfs

| Bereich           | Bewertung                   | Konsequenz                                                                                                             |
|-------------------|-----------------------------|------------------------------------------------------------------------------------------------------------------------|
| Grundsichten      | bleiben gültig              | Keine neue Schicht erforderlich; vorhandene Schichten müssen um Zertifikatslogik ergänzt werden.                       |
| Datenmodell       | muss ergänzt werden         | EntryType HttpsTlsCertificate und zusätzliche CustomFieldKinds bzw. Feldkonventionen aufnehmen.                        |
| Application Layer | muss ergänzt werden         | Zertifikats-ViewModels, Templates, Such-/Filterlogik und Ablaufbewertung als Services modellieren.                     |
| Security          | muss präzisiert werden      | Private Keys, PFX-Passwörter und Key-Passphrases als Secrets klassifizieren; Redaction und Clipboard-Schutz erweitern. |
| Storage/.svault   | bleibt grundsätzlich gültig | Formatversion und Modellmigration berücksichtigen; keine Klartext- oder Zusatzdateien erzwingen.                       |
| UI                | muss ergänzt werden         | Eigene Zertifikatsfeldgruppe im Editier- und Detailbereich; ValidTo prominent anzeigen.                                |
| Tests/QA          | muss ergänzt werden         | Domain-, Application-, Security-, Storage- und UI-nahe Tests für Zertifikatsfälle ergänzen.                            |
| ADRs              | soll ergänzt werden         | Neue Entscheidung zu Zertifikatsmodell und Abgrenzung gegen ACME/PKI dokumentieren.                                    |

## 1. Prüfgrundlage und Abgleichsmethode

Geprüft wurden das bestehende Architekturdokument, das fortgeschriebene Pflichtenheft, das kombinierte Lastenheft/Architekturkonzept, die Featuremap/Roadmap, der aktuelle GitHub-Repository-Stand und das neu überarbeitete Pflichtenheft. Der Fokus lag auf Konsistenz: Was fordert das Pflichtenheft jetzt, was bildet das Architekturdokument bereits ab, und wo entstehen Lücken oder Widersprüche?

Die Prüfung unterscheidet zwischen echten Architekturänderungen, Dokumentationsänderungen und späteren Konzeptthemen. Echte Architekturänderungen beeinflussen Klassen, Schichten, Datenfluss, Dateiformat oder Sicherheitsgrenzen. Dokumentationsänderungen machen vorhandene Architekturentscheidungen explizit. Spätere Konzeptthemen werden als V2/V3-Ausbau sichtbar gehalten, aber nicht in V1 hineingezogen.

### 1.1 Quellen und Zweck im Abgleich

| Quelle                                     | Bedeutung für Architekturprüfung                                                                                 |
|--------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| Bestehendes Architekturdokument V1         | Beschreibt Ist-Architektur und Soll-Ergänzungen bis V1, aber noch ohne konsolidierte Zertifikatsverwaltung.      |
| Überarbeitetes Pflichtenheft 18.05.2026    | Definiert neue verbindliche Umsetzungslogik, vor allem HTTPS/TLS-Zertifikatseinträge, V1-Abnahme und Milestones. |
| Kombiniertes Lastenheft/Architekturkonzept | Bestätigt Grundentscheidungen: internes Modell führend, .svault als Primärformat, Password-Safe-Interop additiv. |
| GitHub-Repository                          | Zeigt die reale Projektstruktur, vorhandene Schichten, aktuellen Prototypstand und offene V1-Themen.             |

## 2. Ergebnis der Architekturprüfung: Was muss geändert werden?

Die bestehende Architektur ist grundsätzlich tragfähig. Sie muss nicht auf WPF, Web, Plugin-System oder Datenbank umgestellt werden. Auch die Schichtentrennung bleibt die richtige Linie. Änderungen sind dennoch erforderlich, weil das Architekturpapier jetzt explizit erklären muss, wie Zertifikate in das Modell passen und welche Funktionen bewusst nicht Teil von V1 sind.

### 2.1 Notwendige Änderungen am Architekturdokument

| Nr.  | Änderung                                                                                                      | Pflichtgrad | Begründung                                                                                                          |
|------|---------------------------------------------------------------------------------------------------------------|-------------|---------------------------------------------------------------------------------------------------------------------|
| A-01 | Zielbild um HTTPS/TLS-Zertifikate als technische Secrets erweitern                                            | Muss        | Das Pflichtenheft nimmt Zertifikate ausdrücklich in V1 auf.                                                         |
| A-02 | Datenmodell um EntryType HttpsTlsCertificate ergänzen                                                         | Muss        | Zertifikate dürfen nicht nur als Notiz oder Custom-Hack erscheinen.                                                 |
| A-03 | CustomFieldKinds bzw. Feldkonventionen für Zertifikatstext, Datum, Fingerprint und Secret-Key-Felder ergänzen | Muss        | Ohne Feldregeln bleiben Suche, Maskierung und UI uneindeutig.                                                       |
| A-04 | Application Services für Zertifikatseinträge beschreiben                                                      | Muss        | Templates, ViewModels, Suche, Ablaufbewertung und Validierungen gehören nicht in MainForm.                          |
| A-05 | Security-Regeln für private Schlüssel und PFX-/Key-Passwörter ergänzen                                        | Muss        | Diese Werte sind hochkritische Secrets und dürfen nicht geloggt oder unsicher kopiert werden.                       |
| A-06 | UI-Architektur für Zertifikatsfeldgruppe beschreiben                                                          | Muss        | Der Nutzer soll Domain, SANS, Ablaufdatum und sensible Felder klar getrennt sehen.                                  |
| A-07 | Storage-/Formatversionierung prüfen                                                                           | Soll        | Das bestehende .svault-Format kann bleiben, braucht aber Modellversion und Migration für neue EntryTypes/Feldarten. |
| A-08 | Test- und QA-Sicht erweitern                                                                                  | Muss        | Zertifikatsmodelle, Suche, Redaction und Ablaufwarnungen brauchen Tests.                                            |
| A-09 | Roadmap/Milestones um Zertifikats-Milestone ergänzen                                                          | Soll        | Die V1-Lücke wird dadurch steuerbar.                                                                                |
| A-10 | ADRs ergänzen                                                                                                 | Soll        | Mindestens eine ADR zur Zertifikatsverwaltung und eine zur Abgrenzung gegen ACME/PKI.                               |

**Wichtig.** Die Zertifikatsverwaltung ist ein Modell- und UI-Ausbau, aber kein Grund, die Architektur auf eine PKI- oder Serverautomatisierungsplattform umzubauen.

## 3. Dinge, die ausdrücklich nicht geändert werden sollten

Ein guter Architekturabgleich benennt nicht nur Ergänzungen, sondern schützt auch stabile Entscheidungen. Mehrere frühere Entscheidungen bleiben richtig und sollten nicht aus Versehen verwässert werden.

### 3.1 Stabile Architekturentscheidungen

| Entscheidung                                         | Bleibt bestehen, weil...                                                                                    |
|------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Lokale Windows-Desktop-Anwendung                     | Das Produkt ist bewusst offline-first, Single-User-orientiert und nicht als Cloud-Dienst konzipiert.        |
| WinForms/.NET 8 für V1                               | Der aktuelle Prototyp steht bereits auf dieser Basis; ein UI-Technologiewechsel würde V1 unnötig verzögern. |
| Internes .svault als Primärformat                    | Das interne Modell bleibt führend; Password Safe ist Interop, nicht Kernformat.                             |
| Domain/Application/Security/Storage/Interop/UI/Tests | Die Schichtentrennung ist genau das richtige Gegenmittel gegen eine monolithische Form-Klasse.              |
| Ein aktiver schreibbarer Tresor pro Fenster          | Konflikte, Locking und Speichern bleiben dadurch beherrschbar.                                              |
| Keine Recovery-Backdoor                              | Die neue Zertifikatsverwaltung ändert nichts am Prinzip: kein versteckter Notzugang.                        |
| Kein ACME/PKI in V1                                  | Zertifikate werden strukturiert verwaltet, aber nicht automatisch erneuert oder deployed.                   |

## 4. Überarbeitetes Zielbild der Architektur

Die V1 des SASD Desktop Secret Managers bleibt eine lokale, sicherheitsbewusste Einzelbenutzeranwendung für Windows. Sie verwaltet mehrere unabhängige verschlüsselte Tresore und unterstützt klassische Logins sowie technische Secret-Kontexte. Neu ausdrücklich im Zielbild ist der Secret-Typ HTTPS/TLS-Zertifikat.

Architektonisch bedeutet das: Ein Zertifikatseintrag wird wie jeder andere Eintrag im internen Modell gespeichert, erhält aber typspezifische Feldvorschläge, Detaildarstellung, Suchregeln und Sicherheitsregeln. Zertifikatsinformationen werden nicht als Sonderdatei neben dem Tresor geführt und nicht in eine externe Datenbank ausgelagert.

### 4.1 Aktualisiertes V1-Zielbild

| Aspekt      | Architekturentscheidung                                                                                                                                 |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Produktform | Lokale Windows-Anwendung mit WinForms/.NET 8.                                                                                                           |
| Persistenz  | Eigenes .svault-Format mit verschlüsseltem Payload, Formatversion und KDF-Parametern.                                                                   |
| Datenmodell | Vault, Group, SecretEntry, Tag, CustomField; erweitert um EntryType HtpsTlsCertificate.                                                                 |
| Security    | AES-256-GCM/PBKDF2-Linie des aktuellen Prototyps bleibt akzeptiert, wenn KDF-Profile versioniert und später migrierbar sind.                            |
| Zertifikate | Manuelle strukturierte Erfassung von Domain, SANs, Issuer, Seriennummer, Fingerprint, Gültigkeit, Deployment-Ziel und sensiblen Key-/PFX-Informationen. |
| Nicht-Ziel  | Keine automatische Zertifikatserneuerung, kein ACME-Client, keine PKI-Verwaltung, kein Server-Deployment in V1.                                         |

## 5. Aktualisiertes Schichtenmodell

Das Schichtenmodell bleibt unverändert in seiner Grundform, wird aber um konkrete Verantwortlichkeiten für Zertifikate ergänzt. Dadurch wird verhindert, dass Zertifikatslogik in der MainForm oder in unscharfen CustomFields verschwindet.

### 5.1 Schichten und neue Zertifikatsverantwortung

| Schicht              | Bestehende Verantwortung                                       | Ergänzung durch Pflichtenheft                                                                                                   |
|----------------------|----------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Domain               | Vault, EntryGroup, SecretEntry, EntryType, CustomField.        | EntryType HtpsTlsCertificate; ggf. CustomFieldKind CertificateText, MultilineText, Date; Feldkonventionen für Zertifikatsdaten. |
| Application          | Query, Mutationen, Organisation, ViewModels, UX-Regeln.        | CertificateEntryTemplateService, CertificateDetailViewModel, CertificateExpiryPolicy, Zertifikatssuche und Validierung.         |
| Security             | KDF, Verschlüsselung, Passwortbewertung, DevLog.               | ClipboardProtectionService, RedactionPolicy für PrivateKey/PFX/Token, AutoLockService, Passwortgenerator.                       |
| Storage              | .svault Container, JSON Payload, atomisches Speichern, Backup. | Format-/ModelVersion-Handling für neue EntryTypes/Feldarten; spätere Attachment-Migration vorbereiten.                          |
| Interop.PasswordSafe | Vorbereitet für .psafe3-Import.                                | Mapping-Regeln dürfen Zertifikats-EntryType nicht blockieren; Import kann unbekannte Felder als CustomFields übernehmen.        |
| WinForms/UI          | MainForm, Dialoge, Detailpanel, Kontextmenüs, Drag-and-Drop.   | Zertifikatsfeldgruppe im EntryEditDialog; Detailansicht mit Domain, ValidTo, SANs und Secret-Key-Bereich.                       |
| Tests                | Domain/Application/Security/Storage/Interop Tests.             | Spezifische Zertifikats-, Redaction-, Suche- und UI-nahe QA-Fälle ergänzen.                                                     |

**Architekturregel.** Neue Zertifikatslogik darf MainForm nicht weiter aufblasen. MainForm orchestriert nur; Fachregeln gehören in Application-Services und ViewModels.

## 6. Aktualisiertes Domain-Modell

Das Domain-Modell bleibt bewusst klein. Es soll nicht für jeden Secret-Typ eine eigene Klassenhierarchie erzeugen. Der richtige Weg ist ein starker SecretEntry mit EntryType und strukturierten CustomFields. Für Zertifikate reicht das, wenn Feldnamen, Feldtypen und Secret-Kennzeichnung sauber definiert werden.

### 6.1 Neue oder erweiterte Domain-Bausteine

| Baustein                        | Architekturentscheidung                                                                         |
|---------------------------------|-------------------------------------------------------------------------------------------------|
| EntryType.HttpsTlsCertificate   | Neuer Typ für Zertifikate, Zertifikatsbezüge und Zertifikatsinstallationen.                     |
| CustomFieldKind.CertificateText | Mehrzeiliger PEM/CRT-Zertifikatstext; nicht automatisch Secret, aber kontrolliert darzustellen. |
| CustomFieldKind.Date            | Gültigkeitsdaten wie ValidFrom, ValidTo, NextRenewalReminder.                                   |
| CustomFieldKind.MultilineText   | SAN-Liste, Chain-Hinweise oder Deployment-Notizen.                                              |
| Secret-markierte Felder         | PrivateKeyPem, PfxPassword, PrivateKeyPassphrase, Token oder sonstige Schlüsselwerte.           |
| ModelVersion                    | Muss erhöht bzw. migrationsfähig bleiben, wenn neue EntryTypes/Feldarten eingeführt werden.     |

### 6.2 Empfohlene Feldkonventionen für Zertifikatseinträge

| Feld                         | Kind                   | Secret | Version | Bemerkung                                                        |
|------------------------------|------------------------|--------|---------|------------------------------------------------------------------|
| PrimaryDomain/<br>CommonName | Hostname/Text          | Nein   | V1      | Mindestfeld für Wiederauffindbarkeit.                            |
| SubjectAlternativeNames      | MultilineText          | Nein   | V1      | Liste von DNS-Namen; Suchlogik muss sie berücksichtigen.         |
| Issuer                       | Text                   | Nein   | V1      | CA oder Aussteller.                                              |
| SerialNumber                 | Text                   | Nein   | V1      | Identifikation beim Provider oder in Logs.                       |
| FingerprintSha256            | Text                   | Nein   | V1      | Kontrollwert; keine automatische Vertrauensprüfung in V1.        |
| ValidFrom                    | Date                   | Nein   | V1      | Gültigkeitsbeginn.                                               |
| ValidTo                      | Date                   | Nein   | V1      | Ablaufdatum; zentral für UI und Warnungen.                       |
| DeploymentTarget             | Text                   | Nein   | V1      | Server, Webpace, Reverse Proxy, Anwendung.                       |
| RenewalMethod                | Text                   | Nein   | V1      | Manuell, Provider, externe ACME, interne CA.                     |
| PrivateKeyLocation           | Text                   | Nein   | V1      | Hinweis auf Ablageort, wenn der Schlüssel nicht im Tresor liegt. |
| PfxPassword                  | Secret                 | Ja     | V1      | Clipboard-geschützt und nie loggen.                              |
| PrivateKeyPassphrase         | Secret                 | Ja     | V1      | Clipboard-geschützt und nie loggen.                              |
| CertificatePem               | CertificateText        | Nein   | V1/V2   | Kann gespeichert werden, aber Datei-Anhänge erst später.         |
| PrivateKeyPem                | CertificateText/Secret | Ja     | V1/V2   | Nur bewusst und mit Warnhinweis.                                 |

## 7. Aktualisierte Application-Schicht

Die Application-Schicht muss die neuen fachlichen Regeln tragen. Zertifikatslogik ist nicht nur UI-Kosmetik: Felder müssen normalisiert, angezeigt, durchsucht, validiert und später nach Ablaufdatum bewertet werden. Daher sollten neue kleine Services entstehen.

### 7.1 Empfohlene Application-Bausteine

| Baustein                        | Aufgabe                                                                                         | Version |
|---------------------------------|-------------------------------------------------------------------------------------------------|---------|
| CertificateEntryTemplateService | Erzeugt ein EntryEditModel mit typischen Zertifikatsfeldern und sinnvollen Sortierreihenfolgen. | V1      |

|                            |                                                                                                     |      |
|----------------------------|-----------------------------------------------------------------------------------------------------|------|
| CertificateFieldNames      | Zentrale Konstanten für Feldnamen wie ValidTo, SANS, Issuer, Fingerprint.                           | V1   |
| CertificateDetailViewModel | Bereitet Domain/CN, SANS, ValidTo, Issuer und Secret-Key-Bereich für die Detailansicht auf.         | V1   |
| CertificateSearchFacet     | Sorgt dafür, dass Domain, SANS, Issuer, Fingerprint und DeploymentTarget gefunden werden.           | V1   |
| CertificateExpiryPolicy    | Bewertet Ablaufstatus: gültig, läuft bald ab, abgelaufen; Schwellwerte konfigurierbar.              | V1.x |
| EntryTemplateService       | Generischer Einstieg für Templates, der auch Login, Mail, Database, API und Zertifikat unterstützt. | V1.x |

Die vorhandenen Services wie EntryMutationService, VaultQueryService und VaultUxPolicyService bleiben sinnvoll. Sie sollten aber so erweitert werden, dass neue EntryTypes nicht per Sonderfall in der MainForm landen.

## 8. Aktualisierte Security-Architektur

Die Zertifikatsverwaltung erhöht die Bedeutung der Secret-Klassifizierung. Ein öffentlicher Zertifikatstext ist nicht automatisch geheim, ein privater Schlüssel dagegen ist besonders kritisch. Die Architektur muss diese Unterscheidung sichtbar machen.

### 8.1 Security-Ergänzungen

| Thema                      | Architekturentscheidung                                                                                                                |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Secret-Klassifizierung     | Nicht der EntryType allein entscheidet, sondern CustomField.IsSecret und bekannte Feldnamen wie PrivateKeyPem, PfxPassword oder Token. |
| ClipboardProtectionService | Alle Copy-Aktionen für Secret-Felder laufen zentral; Auto-Clear und Statusfeedback gehören hierher.                                    |
| RedactionPolicy            | Logs, Fehlermeldungen, Importberichte und Debugausgaben müssen bekannte Secret-Feldnamen schwärzen.                                    |
| AutoLockService            | Beim Lock werden Detailansicht, Reveal-Zustände und kopierbare Secretwerte zurückgesetzt.                                              |
| PasswordGeneratorService   | Generatorlogik in Security/Application, nicht in Dialogcode; erzeugte Werte nicht loggen.                                              |
| KDF-Strategie              | Aktueller PBKDF2-SHA256/AES-256-GCM-Stand bleibt dokumentiert; spätere Argon2id-Migration über KDF-Profil vorbereiten.                 |

**Zertifikats-Sicherheitsgrenze.** Das Speichern privater Schlüssel im Tresor kann fachlich nützlich sein, ist aber besonders sensibel. Die UI muss warnen, die Logs müssen redigieren, und Exporte müssen explizit abgesichert werden.

## 9. Storage, Dateiformat und Migration

Das .svault-Format bleibt das Primärformat. Die Zertifikatsverwaltung erzwingt keine neue Speichertechnologie. Weil das interne Modell als JSON-Payload verschlüsselt gespeichert wird, können neue EntryTypes und CustomFields grundsätzlich im bestehenden Format mitgeführt werden. Trotzdem muss die Architektur Versions- und Migrationsregeln benennen.

### 9.1 Storage-Konsequenzen

| Punkt                   | Entscheidung                                                                                                               |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Formatversion           | Neue EntryTypes und FieldKinds müssen in ModelVersion oder FormatVersion nachvollziehbar sein.                             |
| Rückwärtskompatibilität | Ältere Clients sollen unbekannte Typen nicht stillschweigend zerstören; mindestens Fehlermeldung oder read-only-Verhalten. |
| Backups                 | Backup-Dateien bleiben verschlüsselt; keine Zertifikats- oder Schlüsseldateien neben dem Tresor.                           |
| Anhänge                 | V2-Thema. Für CRT/PFX/Chain-Dateien ist später ein verschlüsseltes Attachment-Modell nötig.                                |
| Temporäre Dateien       | Keine unverschlüsselten temporären Zertifikats- oder Private-Key-Dateien erzeugen.                                         |
| Export                  | CSV/JSON/.psafe3-Export muss Secret-Felder und Zertifikatsdaten mit Warnungen behandeln.                                   |

## 10. UI- und UX-Architektur

Die UI muss die neue fachliche Vielfalt sichtbar machen, ohne unruhig zu werden. Zertifikatseinträge sollen nicht als chaotische CustomField-Liste erscheinen, sondern in einer verständlichen Feldgruppe. Das stärkt die Alltagstauglichkeit und verhindert Missverständnisse.

### 10.1 UI-Ergänzungen

| UI-Bereich        | Ergänzung                                                                                                                                                  |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EntryEditDialog   | Bei EntryType <code>HttpsTlsCertificate</code> eine Feldgruppe Identität, Gültigkeit, Aussteller/Fingerprint, Deployment, sensible Schlüssel/PFX anbieten. |
| EntryDetailsPanel | Domain/CN, ValidTo und Issuer prominent anzeigen; Secret-Felder maskiert und separat gruppieren.                                                           |
| EntryListView     | Optional Spalte ValidTo für Zertifikate; keine Secret-Werte in Listen.                                                                                     |
| Suche/Filter      | Typfilter für Zertifikate; Suche über Domain, SANS, Issuer, DeploymentTarget.                                                                              |
| Statusleiste      | Warnungen zu Copy-Aktionen, ablaufenden Zertifikaten und Importhinweisen anzeigen.                                                                         |
| Warnhinweise      | Beim Einfügen privater Schlüssel oder PFX-Passwörter klarer Hinweis auf Sensibilität.                                                                      |

Die bestehende Drei-Zonen-Oberfläche bleibt geeignet: links Gruppenbaum, mittig Suche/ListView, rechts Details. Das Architekturpapier sollte aber festhalten, dass weitere typspezifische Panels nicht direkt in MainForm wachsen sollen.

## 11. Password-Safe-Interop und Zertifikatsdaten

Password Safe bleibt eine additive Interop-Schicht. Der neue Zertifikatstyp ändert daran nichts. Die Interop-Schicht muss aber mit unbekannten, fremden oder nicht sauber abbildbaren Informationen ehrlich umgehen. Importierte Felder werden entweder direkt gemappt, als CustomFields übernommen oder im Importbericht dokumentiert.

### 11.1 Interop-Konsequenzen

| Thema                           | Entscheidung                                                                                                                                     |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| .psafe3-Import                  | Soll interne EntryTypes nutzen, wenn Mapping möglich ist; ansonsten Custom/Imported Metadata.                                                    |
| Zertifikatsdaten aus Fremddaten | Wenn Zertifikatsfelder erkannt werden, können sie als <code>HttpsTlsCertificate</code> oder als CustomFields landen; niemals still verschlucken. |
| .psafe3-Export                  | Zertifikatseinträge sind wahrscheinlich nur verlustbehaftet exportierbar; Exportbericht muss das zeigen.                                         |
| CSV-Export                      | PrivateKey/PFX/Passphrases als besonders riskant kennzeichnen; Export nur nach Warnung.                                                          |

## 12. Laufzeitsichten und Kernabläufe

Das Architekturdokument sollte mehrere Laufzeitsichten ergänzen, damit die Umsetzung nicht missverstanden wird. Besonders wichtig sind die Abläufe Zertifikatseintrag anlegen, Secret kopieren, Auto-Lock und Import.

### 12.1 Kernabläufe

| Ablauf                     | Architekturfluss                                                                                                                                                |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Tresor öffnen              | UI fragt Master-Passwort ab; Storage lädt Container; Security leitet Schlüssel ab; Domain wird deserialisiert; Application normalisiert; UI baut Views neu auf. |
| Zertifikatseintrag anlegen | UI wählt EntryType; Application erzeugt Template; Nutzer füllt Felder; EntryMutationService normalisiert CustomFields; Vault wird dirty.                        |
| Zertifikat suchen          | UI sendet Suchtext/Filter; VaultQueryService durchsucht Titel, Typ, Tags, Domain, SANS, Issuer, DeploymentTarget und nicht-geheime Felder.                      |
| Secret-Feld kopieren       | Detailpanel ruft zentralen ClipboardProtectionService auf; Statusfeedback; Auto-Clear nach Zeit; keine Logs.                                                    |
| Auto-Lock                  | AutoLockService erkennt Inaktivität; UI maskiert/leert Details; Session wird gesperrt; Entsperren nur mit Master-Passwort.                                      |



|                |                                                                                                                          |
|----------------|--------------------------------------------------------------------------------------------------------------------------|
| .psafe3-Import | Interop liest Quelle; Mapper erzeugt interne Einträge; Importbericht dokumentiert Warnungen; Nutzer bestätigt Übernahme. |
|----------------|--------------------------------------------------------------------------------------------------------------------------|

## 13. Test- und Verifikationssicht

Die Tests müssen den erweiterten Scope spiegeln. Besonders wichtig sind negative Tests und Secret-Leak-Tests, weil Zertifikatsdaten private Schlüssel und PFX-Passwörter enthalten können.

### 13.1 Neue oder erweiterte Tests

| Ebene       | Testfälle                                                                                                                                           |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Domain      | EntryType HttpsTlsCertificate serialisierbar; FieldKinds Date/CertificateText/Secret; Tags und Gruppen unverändert.                                 |
| Application | Template erzeugt erwartete Felder; Suchlogik findet SANs und Issuer; Ablaufbewertung korrekt; UpdateEntry markiert dirty nur bei echten Änderungen. |
| Security    | Redaction schwärzt PrivateKey/PFX/Passphrases; Clipboard-Autoclear funktioniert; Auto-Lock entfernt sichtbare Secrets.                              |
| Storage     | Speichern/Laden von Zertifikatseinträgen; ältere/neuere ModelVersion; beschädigte Dateien; keine Klartext-Temp-Dateien.                             |
| Interop     | Importbericht bei nicht abbildbaren Feldern; Zertifikatsfelder als CustomFields oder passender Typ.                                                 |
| Manuelle QA | Zertifikatseintrag anlegen, suchen, kopieren, sperren, wieder öffnen, ablaufendes Zertifikat erkennen.                                              |

## 14. ADRs und Dokumentationsfolgen

Das Repository enthält bereits Architekturentscheidungen zur führenden Rolle des internen Datenmodells, zum .svault-Primärformat, zur Password-Safe-Interop, zu mehreren Tresoren und zur fehlenden Recovery-Backdoor. Durch die neue Zertifikatsverwaltung sollten mindestens zwei weitere ADRs ergänzt werden.

### 14.1 Empfohlene neue ADRs

| ADR              | Titel                                                       | Kernaussage                                                                                                          |
|------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| ADR-006          | HTTPS/TLS-Zertifikate als EntryType statt Sonderdateisystem | Zertifikate werden im internen Entry-/CustomField-Modell abgebildet; private Schlüssel sind Secret-Felder.           |
| ADR-007          | Keine ACME-/PKI-Automation in V1                            | V1 verwaltet Zertifikatsinformationen, erneuert oder deployed Zertifikate aber nicht automatisch.                    |
| ADR-008 optional | KDF-Migrationsstrategie                                     | Aktuelle PBKDF2-SHA256-Linie bleibt für Prototyp/V1 zulässig, solange KDF-Profil versioniert und migrierbar bleiben. |

Zusätzlich sollten README, Roadmap und Benutzerkurzdokumentation später denselben Stand spiegeln: Zertifikate ja, PKI-Automation nein, private Schlüssel nur bewusst und geschützt.

## 15. Aktualisierte Roadmap und Umsetzungspakete

Die Roadmap sollte die neue Zertifikatsfunktion nicht irgendwo zwischen allgemeiner Suche und Interop verstecken. Ein eigener Milestone schafft Klarheit und verhindert, dass Zertifikatslogik halb im UI und halb als CustomField-Nebene entsteht.

### 15.1 Empfohlene Milestone-Reihenfolge bis V1

| Milestone | Ziel                                | Architekturhinweis                                                            |
|-----------|-------------------------------------|-------------------------------------------------------------------------------|
| M12       | Clipboard-Schutz und Secret-Komfort | Zentraler ClipboardProtectionService vor Zertifikats-Private-Key-Feldern.     |
| M13       | Dirty-State und Datenverlustschutz  | Sicheres Speichern/Verwerfen vor weiteren Modell-Erweiterungen stabilisieren. |
| M14       | Lock/Auto-Lock                      | Session-Schutz und UI-Maskierung verlässlich machen.                          |

|     |                                   |                                                                        |
|-----|-----------------------------------|------------------------------------------------------------------------|
| M15 | Passwortgenerator                 | Security/Application-Service, nicht Dialog-Einzelcode.                 |
| M16 | HTTPS/TLS-Zertifikatseintrag      | EntryType, Feldkonventionen, ViewModel, Edit-/Detail-UI, Suche, Tests. |
| M17 | Backup/Restore und Dateikonflikte | Backups, Fehlerfälle, Locking und keine Klartextreste.                 |
| M18 | Suche und Filter alltagstauglich  | Typ-/Tagfilter, Zusatzfeldsuche, Zertifikatssuche.                     |
| M19 | Password-Safe-Import              | Reader, Mapping, Importbericht.                                        |
| M20 | Release-Härtung                   | Security-Review, QA, Doku und Paketierung.                             |

## 16. Risiken und bewusste Grenzen

### 16.1 Risiken und Architekturmaßnahmen

| Risiko                                        | Maßnahme                                                                                  |
|-----------------------------------------------|-------------------------------------------------------------------------------------------|
| Zertifikatsverwaltung driftet in PKI-Suite    | V1 strikt auf strukturierte lokale Verwaltung begrenzen; ACME/PKI als V3-Konzept.         |
| Private Keys werden versehentlich offengelegt | Secret-Kennzeichnung, RedactionPolicy, ClipboardProtectionService, Warnhinweis und Tests. |
| MainForm wird zu groß                         | Certificate Services und ViewModels einführen; UI nur orchestrieren lassen.               |
| Datenformat wird inkonsistent                 | ModelVersion und Feldkonventionen dokumentieren; Migrationen vorbereiten.                 |
| Falsche Sicherheitserwartung                  | Schutzgrenzen und Nicht-Ziele explizit nennen.                                            |
| Interop-Verlust bei Export                    | Exportberichte und klare Warnungen statt stiller Konvertierung.                           |

## 17. Konkrete Änderungsliste für das bestehende Architekturdokument

Die folgende Liste kann direkt als Redaktions-Checkliste verwendet werden, wenn das bestehende Architekturdokument im Repository aktualisiert wird.

### 17.1 Redaktions- und Strukturänderungen

| Kapitel im Architekturdokument | Änderung                                                                                                              |
|--------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Titel/Metadaten                | Stand auf 18.05.2026 oder aktuellen Repository-Stand setzen; Bezug auf überarbeitetes Lasten-/Pflichtenheft ergänzen. |
| Management Summary             | Zertifikatsverwaltung als neu integrierten Secret-Kontext erwähnen.                                                   |
| Zielbild/Abgrenzung            | V1 umfasst HTTPS/TLS-Zertifikatseinträge; V1 umfasst nicht ACME/PKI/Deployment.                                       |
| Schichtenmodell                | Zertifikatsverantwortung je Schicht ergänzen.                                                                         |
| Laufzeitsicht                  | Ablauf Zertifikatseintrag anlegen, suchen, kopieren, sperren ergänzen.                                                |
| Datenmodell                    | EntryType, FieldKinds, Feldkonventionen und Secret-Klassifizierung ergänzen.                                          |
| Klassenbeschreibung            | Vorgeschlagene neue Services/ViewModels aufnehmen.                                                                    |
| Speicher-/Krypto-Konzept       | ModelVersion/KDF-Profil/Migration und keine Klartext-Temp-Dateien betonen.                                            |
| UX                             | Zertifikats-Editor-/Detailgruppe, ValidTo-Anzeige und Warnhinweise ergänzen.                                          |
| Tests                          | Zertifikats-, Redaction-, Suche- und Speicherfälle ergänzen.                                                          |
| Risiken                        | PKI-Scope-Creep, Private-Key-Leaks, Exportwarnungen ergänzen.                                                         |
| Anhang                         | Neue Klassen-/Servicevorschläge und ADR-Liste aufnehmen.                                                              |

**Fazit.** Die Architektur bleibt stabil, aber das Dokument muss aktualisiert werden. Ohne Aktualisierung wäre das Architekturdokument hinter Lastenheft und Pflichtenheft zurück und würde gerade beim Zertifikatsthema zu Missverständnissen führen.

## Anhang A - Empfohlene neue oder geänderte Klassen

### A.1 Klassen- und Servicevorschläge

| Schicht | Baustein                      | Aufgabe                           |
|---------|-------------------------------|-----------------------------------|
| Domain  | EntryType.HttpsTlsCertificate | Neuer Secret-Typ für Zertifikate. |

|             |                                 |                                                                  |
|-------------|---------------------------------|------------------------------------------------------------------|
| Domain      | CustomFieldKind.CertificateText | Mehrzeilige Zertifikats-/PEM-Texte fachlich kennzeichnen.        |
| Application | CertificateFieldNames           | Zentrale Feldnamenkonstanten für robuste Suche und Redaction.    |
| Application | CertificateEntryTemplateService | Initiale Felder und Sortierung für Zertifikatseinträge erzeugen. |
| Application | CertificateDetailViewModel      | Zertifikatsdaten für Detailansicht aufbereiten.                  |
| Application | CertificateExpiryPolicy         | Ablaufstatus und Warnschwellen bewerten.                         |
| Security    | ClipboardProtectionService      | Sensible Copy-Aktionen zentral steuern.                          |
| Security    | RedactionPolicy                 | Bekannte Secret-Felder vor Logging/Fehlermeldungen schützen.     |
| Security    | AutoLockService                 | Sperr- und Entsperrlogik koordinieren.                           |
| Security    | PasswordGeneratorService        | Passwörter sicher generieren und nicht protokollieren.           |
| WinForms    | CertificateFieldsPanel          | Typspezifische UI für Zertifikatsfelder.                         |
| Tests       | CertificateEntryTests           | Domain- und Application-Tests für Zertifikatseinträge.           |

## Anhang B - Abnahme- und Review-Checkliste

### B.1 Architektur-Review nach Aktualisierung

| Prüfpunkt                          | Erwartetes Ergebnis                                                    |
|------------------------------------|------------------------------------------------------------------------|
| Zertifikats-EntryType dokumentiert | Architektur beschreibt Typ, Felder und Grenzen.                        |
| Security-Regeln aktualisiert       | Private Keys/PFX/Passphrases als Secrets eingestuft.                   |
| UI nicht überladen                 | Zertifikatsfelder in eigener Gruppe statt wildem Formular.             |
| Storage nicht unnötig erweitert    | .svault bleibt primär, Modellversion/Migration dokumentiert.           |
| Tests benannt                      | Alle relevanten Testebenen enthalten Zertifikatsfälle.                 |
| ADRs ergänzt                       | Zertifikatsmodell und ACME/PKI-Abgrenzung entschieden.                 |
| Roadmap konsistent                 | M16 oder äquivalenter Milestone vorhanden.                             |
| Nicht-Ziele klar                   | Keine implizite Zusage von ACME, Deployment oder Team-/Cloud-Funktion. |